

Database, API & Non-Functional Requirements

Part 3 of the GymX Software Requirements Specification addresses the foundational infrastructure layers that govern data persistence, application integration, and system-wide quality attributes. Developers and system architects will find the contractual requirements for PostgreSQL configuration, RESTful API design, security enforcement, and operational resilience documented herein. Every specification in this section carries the force of a hard requirement — the platform **shall** implement each item as described.

This document spans nine major sections (§16–§24), covering database entities and relationships, API endpoint catalogues, non-functional quality attributes, security controls, error handling conventions, validation rules, logging and monitoring, backup and recovery, and a roadmap of future enhancements. Together, these requirements form the engineering backbone of the GymX platform.

Database Requirements

The GymX platform shall use **PostgreSQL** as the primary relational database management system. PostgreSQL was selected for its enterprise-grade reliability, native ACID compliance, advanced indexing capabilities, and robust ecosystem of tooling. The database must ensure data integrity, high performance, scalability, secure storage, ACID compliance, and backup-and-recovery support. All schemas shall be normalised to at least Third Normal Form (3NF) to eliminate data redundancy and update anomalies.

Core Guarantees

PostgreSQL's MVCC engine provides non-blocking reads, serialisable isolation when required, and checkpoint-based crash recovery. Foreign-key constraints enforce referential integrity across every relationship in the domain model.

Normalisation Target

Normalisation to 3NF guarantees that every non-key attribute depends on the key, the whole key, and nothing but the key. Denormalisation may be introduced selectively in read-model projections, but the transactional schema remains fully normalised.

Domain Entities

The system shall include — but is not limited to — thirty distinct domain entities spanning identity, membership, fitness, nutrition, operations, and administration. These entities form the backbone of the GymX data model and must be modelled with proper primary keys, foreign keys, indexes, and constraints.

Identity & Access

Users, Roles, Permissions — the RBAC triad governing authentication and authorisation across the platform.

People

Members, Employees, Coaches, Nutritionists — all human actors modelled with shared base attributes and role-specific extensions.

Membership & Billing

Branches, Plans, Memberships, Payments, Invoices — the commercial backbone tying members to revenue.

Fitness & Nutrition

Workout Plans, Exercises, Categories, Diet Plans, Meals, Food Items — domain content authored by coaches and nutritionists.

Operations

Classes, Bookings, Equipment, Maintenance Records, Inventory, Products, Suppliers — facilities and supply-chain management.

Platform

Notifications, Audit Logs, Settings — cross-cutting infrastructure supporting observability and configuration.

API Requirements

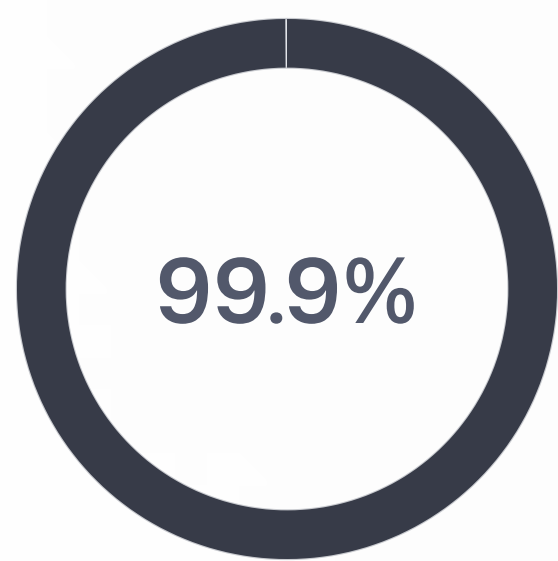
GymX shall expose a secure RESTful API for web and future mobile applications. The API shall use JSON as the data-interchange format, HTTPS as the transport protocol, JWT-based authentication, and REST architectural principles. Every endpoint shall implement request validation, response validation, standard HTTP status codes, descriptive error messages, authentication, and authorisation.

Endpoint Catalogue

Domain	Method	Endpoint
Authentication	POST	/api/auth/login · /api/auth/logout · /api/auth/register · /api/auth/refresh
Members	CRUD	GET · POST · PUT · DELETE /api/members[/]{id}]
Memberships	CRUD	GET · POST · PUT · DELETE /api/memberships[/]{id}]
Attendance	POST + GET	/api/attendance/check-in · /api/attendance/check-out · /api/attendance/history
Payments	POST + GET	/api/payments · /api/invoices
Workout	CRUD	GET · POST · PUT · DELETE /api/workouts[/]{id}]
Nutrition	CRUD	GET · POST · PUT · DELETE /api/diets[/]{id}]

Non-Functional Requirements

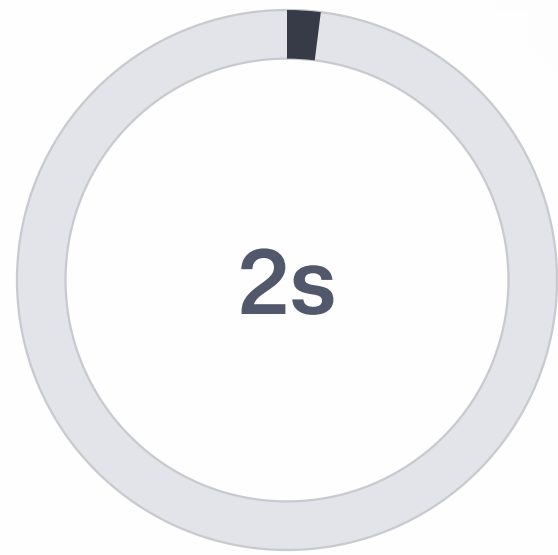
The system shall satisfy six categories of quality attributes. These non-functional requirements define the operational contracts that govern performance, scalability, reliability, availability, maintainability, and accessibility across the GymX platform.



Uptime
Annual availability target



Concurrent Users
Minimum supported parallel load



Page Load
Dashboard render budget



Device Classes
Desktop, tablet, mobile responsive

Performance & Scalability

Dashboards must load within 2 seconds. The platform must support at least 1,000 concurrent users and optimise all database queries. Horizontal scaling and cloud deployment are first-class design constraints, enabling the system to span multiple branches and thousands of active members.

Reliability & Maintainability

Continuous operation, corruption prevention, failure recovery, and transaction consistency are mandatory. The codebase shall follow clean architecture with modular design, readable code, and support for future enhancements without structural rework.

Security Requirements

Security is one of the highest priorities for the GymX platform. The system shall implement a defence-in-depth strategy spanning authentication, transport security, access control, input hardening, and cryptographic storage. Every layer of the stack — from the API gateway to the database — must enforce security controls appropriate to its boundary.



Authentication & Sessions

JWT authentication, refresh tokens, and secure session management govern identity verification.



RBAC

Role-based access control ensures users access only the resources their role permits.



Input Hardening

Validation, SQL injection protection, XSS protection, CSRF protection, and rate limiting at every entry point.



Data Protection

Password hashing, data encryption, and secure file upload safeguard sensitive information at rest and in transit.

Error Handling & Validation

Consistent error handling is essential for API consumers and frontend developers. Every error response shall return a descriptive JSON payload containing a machine-readable error code, a human-readable message, and optional field-level details. Validation rules shall be enforced both at the API boundary and within the domain layer to ensure defence in depth.

HTTP Status Code Map

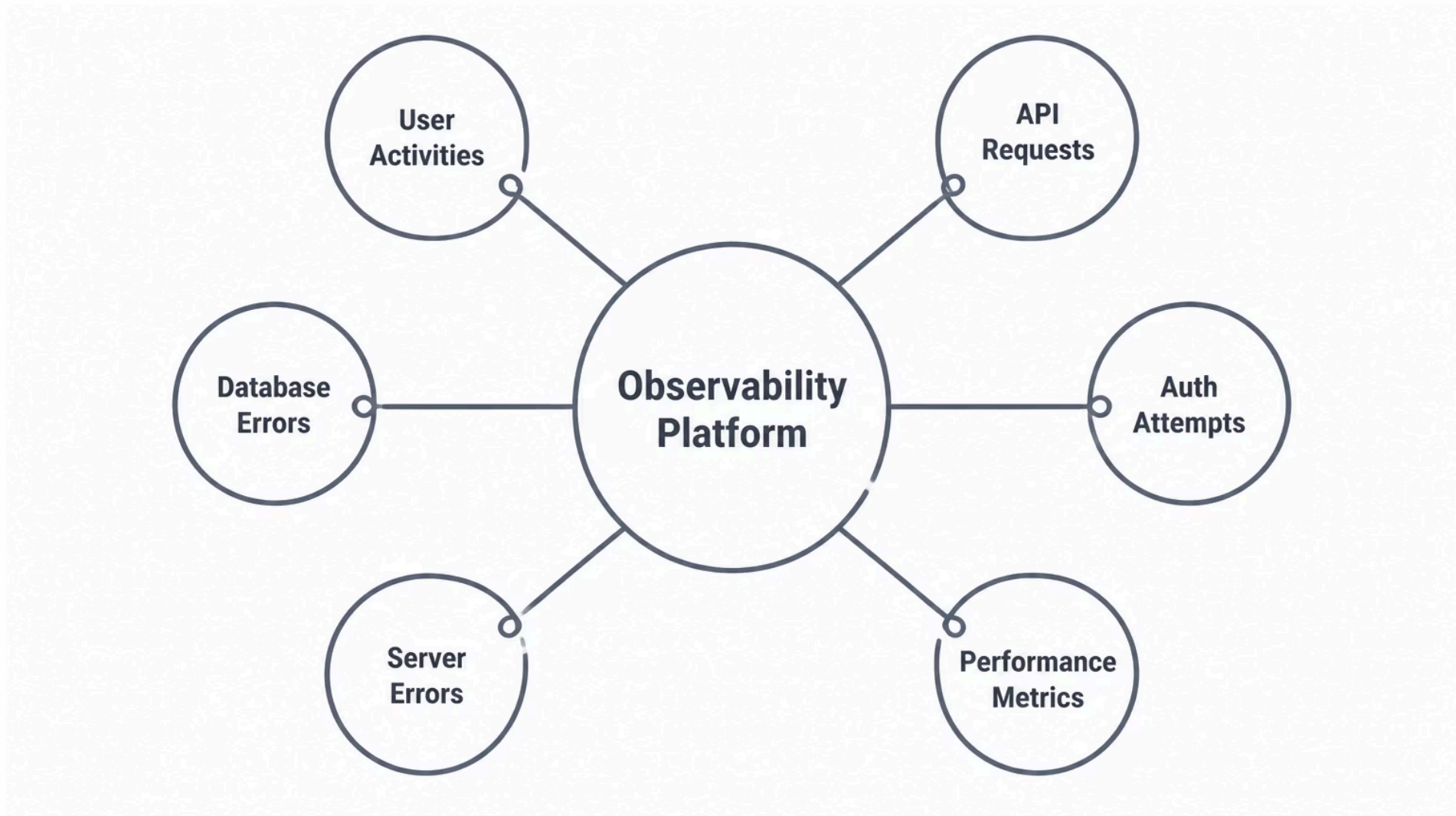
- 400** Bad Request
- 401** Unauthorized
- 403** Forbidden
- 404** Not Found
- 409** Conflict
- 422** Validation Error
- 500** Internal Server Error

Validation Rules

- Email uniqueness across all user records
- Phone number uniqueness across all user records
- Membership expiration date must not be in the past on creation
- Payment amounts must be positive numeric values
- Attendance duplication prevention — one active check-in per member
- All required fields enforced at API and domain layers
- File upload formats restricted to approved MIME types
- File sizes capped at configurable maximums

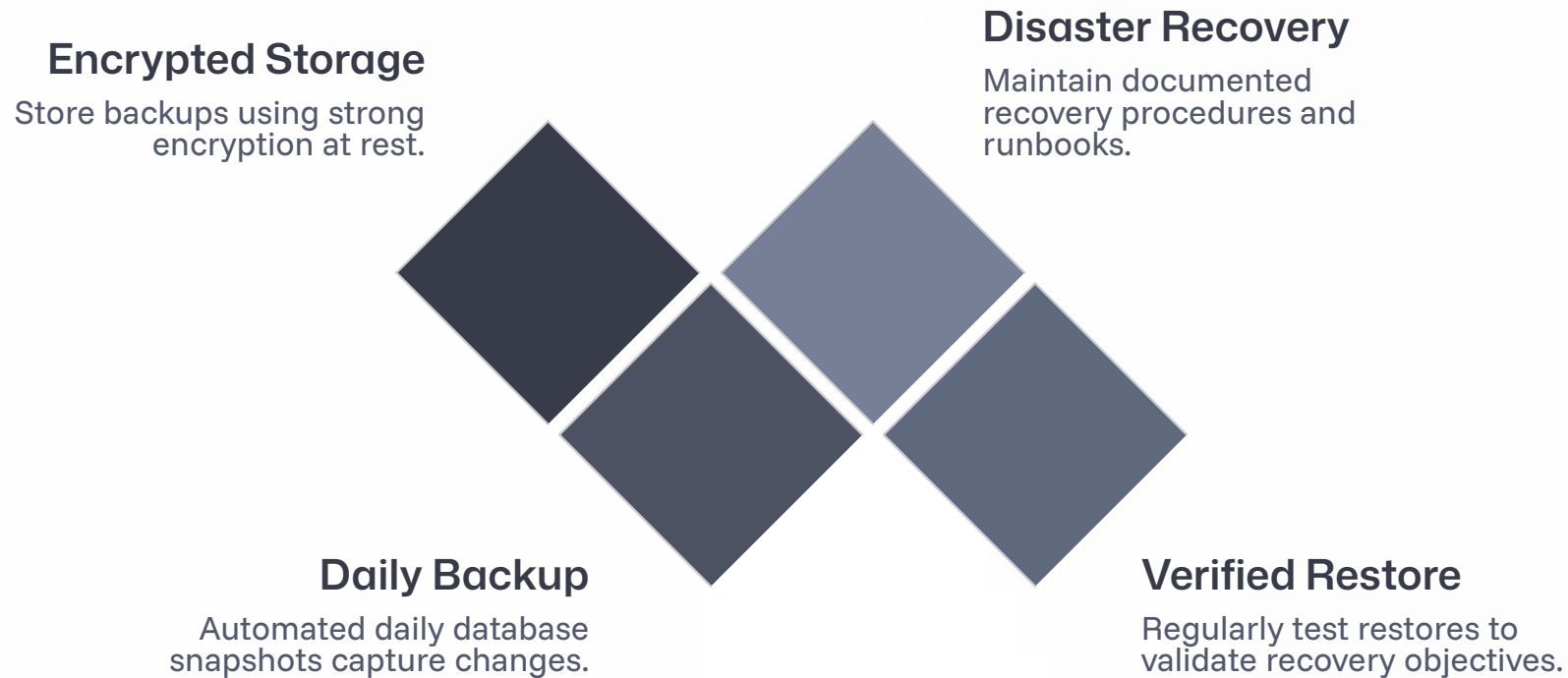
Logging & Monitoring

The platform shall maintain structured logs for user activities, API requests, database errors, authentication attempts, server errors, and performance metrics. Logs must be centralised, queryable, and retained according to the platform's data governance policy. Monitoring tooling may include **Prometheus** for metrics collection, **Grafana** for dashboards and alerting, and **Sentry** for error tracking across the application stack.



Backup & Recovery

The system shall perform daily automated database backups, store them in encrypted form, support disaster recovery procedures, and restore data within acceptable recovery time objectives. Backups must be validated periodically through test-restore cycles to ensure they are not silently corrupted.



Recovery time objectives and recovery point objectives shall be defined per environment. Production environments require the shortest RTO, with point-in-time recovery enabled through PostgreSQL's write-ahead log archiving.

Future Enhancements

Future versions of GymX may incorporate AI-driven personalisation, native mobile experiences, wearable integration, biometric check-in, and IoT-connected equipment. These enhancements are not in scope for the current specification but are documented here to ensure architectural decisions made today do not preclude them tomorrow.



AI Personal Trainer

Adaptive workout recommendations driven by machine learning models trained on member progress data.



Wearables & Smart Watches

Integration with Apple Watch, Garmin, and Fitbit to sync heart rate, steps, and workout completion data in real time.



IoT Gym Equipment

Connected machines that log usage, track maintenance needs, and feed workout data directly into member profiles.



Facial Recognition Check-In

Frictionless member entry using biometric identification — no QR code, no fob, no manual check-in required.